

Security+ 1.4 · Certificates

Mestre CyberSec — PDF baseado na aula do Professor Messer · 1.4 — Certificates (14:38) · [vídeo original ↗](#)
· [YouTube ↗](#)

Certificado digital: arquivo assinado pela CA (Certificate Authority) que liga domínio a chave pública. Self-signed = tu mesmo assina (confiança própria, não deve ir pro público).
CSR = Certificate Signing Request (tu manda a chave pública + identidade pra CA assinar).
CRL (lista de revogados) / OCSP (verificação online) / OCSP stapling (servidor anexa resposta).

💡 Highlights que a prova cobra

- CA assina o certificado — cadeia de confiança root CA → intermediária → leaf
- CSR = requisição de assinatura: contém a chave pública + identidade
- CRL/OCSP/stapling = como o browser checa se certificado foi revogado

🎯 Dicas de prova

- 'contains public key and identity, signed by CA' = certificate
- 'revocation checking method with online query' = OCSP

Cenário clássico: Cenário: 'usuário acessa o site e o cadeado vermelho diz que o certificado não é confiável' — self-signed ou expirado/revocado.

✅ Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. No TLS/HTTPS, o certificado do site serve pra:
- A)** Provar a identidade do servidor e habilitar a troca segura de chave
 - B)** Criptografar o disco
 - C)** Bloquear malware
 - D)** Fazer backup

2. Em uma infraestrutura PKI, qual componente é responsável por validar e revogar certificados digitais?

- A) RA (Registration Authority)
- B) CA (Certificate Authority)
- C) CRL (Certificate Revocation List)
- D) OCSP (Online Certificate Status Protocol)

3. Uma característica de HASH (diferente de criptografia) é que ele:

- A) Pode ser revertido com a chave
- B) É de mão única (não reversível)
- C) Sempre encurta o texto pela metade
- D) Precisa de par de chaves

4. Qual tipo de criptografia usa pares de chaves pública e privada?

- A) Hashing
- B) Criptografia simétrica
- C) Criptografia assimétrica
- D) Steganografia

5. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'CA assina o certificado — cadeia de confiança root CA → intermediária → leaf'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Implementar a solução correspondente: CA assina o certificado — cadeia de confiança root CA → intermediária → lea...
- B) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C) Substituir controles técnicos preventivos por termos de adesão informais
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'CSR = requisição de assinatura: contém a chave pública + identidade'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Implementar a solução correspondente: CSR = requisição de assinatura: contém a chave pública + identidade...
- B) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C) Substituir controles técnicos preventivos por termos de adesão informais
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'CRL/OCSP/stapling = como o browser checa se certificado foi revogado'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: CRL/OCSP/stapling = como o browser checa se certificado foi revogado...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: '"contains public key and identity, signed by CA' = certificate'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'contains public key and identity, signed by CA' = certificate...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: '"revocation checking method with online query' = OCSP'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'revocation checking method with online query' = OCSP...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'usuário acessa o site e o cadeado vermelho diz que o certificado não é confiável' — self-signed ou expirado/revocado.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: 'usuário acessa o site e o cadeado vermelho diz que o certificado ...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) A — Provar a identidade do servidor e habilitar a troca segura de chave.** O certificado (assinado por uma CA) prova que o servidor é quem diz ser e habilita a troca segura da chave da sessão.
- 2) B — CA (Certificate Authority).** A CA (Autoridade Certificadora) emite, valida e revoga certificados. A RA apenas verifica identidades, enquanto CRL e OCSP são mecanismos de verificação de revogação.
- 3) B — É de mão única (não reversível).** Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade.
- 4) C — Criptografia assimétrica.** Criptografia assimétrica (como RSA, ECC) usa par de chaves matematicamente relacionadas: pública para criptografar e privada para descriptografar, ou vice-versa para assinatura.
- 5) A — Implementar a solução correspondente: CA assina o certificado — cadeia de confia.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): CA assina o certificado — cadeia de confiança root CA → intermediária → leaf. As demais alternativas configuram violação
- 6) A — Implementar a solução correspondente: CSR = requisição de assinatura: contém a c.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): CSR = requisição de assinatura: contém a chave pública + identidade. As demais alternativas configuram violações graves
- 7) A — Implementar a solução correspondente: CRL/OCSP/stapling = como o browser checa s.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): CRL/OCSP/stapling = como o browser checa se certificado foi revogado. As demais alternativas configuram violações graves
- 8) C — Implementar a solução correspondente: 'contains public key and identity, signed .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): 'contains public key and identity, signed by CA' = certificate. As demais alternativas configuram violações graves de co
- 9) A — Implementar a solução correspondente: 'revocation checking method with online qu.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): 'revocation checking method with online query' = OCSP. As demais alternativas configuram violações graves de conformidade
- 10) C — Implementar a solução correspondente: Cenário: 'usuário acessa o site e o cadead.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): Cenário: 'usuário acessa o site e o cadeado vermelho diz que o certificado não é confiável' — self-signed ou expirado/re

